

SPRINTEINS

Renovate Introduction

MARIUS SHEKOW

21.5.2026 CLOUDLAND

N

Workshop prerequisites

Chrome / Chromium-based browser



or

Local VS Code installation
with VS Code Live Share extension



N

Start with
why



N

Deps are everywhere

- Situation: software is built on the shoulder of giants
- We use dependencies in many ecosystems, e.g., software (A) or cloud infrastructure (B)
- Because it saves time and improves quality

A: package.json

```
{
  "name": "ui",
  "dependencies": {
    "@emotion/react": "^11.11.1",
    "@emotion/styled": "^11.11.0",
    "@mui/material": "^5.14.20",
    "@mui/x-data-grid": "^6.18.3",
    "react": "^18.2.0",
    "react-dom": "^18.2.0"
  },
  "devDependencies": {
    "vite": "^5.0.0"
  }
}
```

requirements.txt

```
SQLAlchemy==2.0.30
sqlalchemy-utils==0.41.2
PyGithub==2.3.0
python-gitlab==4.6.0
psycopg2-binary==2.9.9
marko==2.0.3
packaging==24.0
tqdm==4.66.4
```

B: main.tf

```
terraform {
  required_version = "~> 1.0"

  required_providers {
    azurerm = {
      source = "hashicorp/azurerm"
      version = "4.64.0"
    }
    postgresql = {
      source = "cyrilgdn/postgresql"
      version = "1.26.0"
    }
  }
}
```

Renovate's purpose

- **Problem:** Dependencies become out of date quickly – you can't keep using the same versions forever
- → unmaintained (no more bugfixes, stop working), or vulnerable / insecure
- Renovate is a tool to
 - provide **transparency** regarding outdated dependencies (=technical debt)
 - make dependency updates **plannable**
 - allows teams to keep a constant development velocity (features / sprint)

The real challenge

Introducing a tool is easy - real challenges:

Convincing your paying (non-technical) customer to allocate a **budget** to

- merge dependency updates
- to improve test suites so that Renovate can merge updates automatically

Having a **motivated team** to work on dependency updates

Establish (and stick to) a **plan** for how to address dependency updates in general (what's in scope, prioritization order)

How to address the 85 PRs Renovate created in an old project?

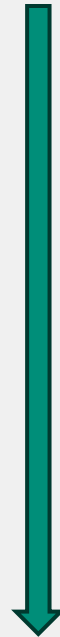
N

What Renovate does



What is Renovate?

- **CLI**, visits one or more repos in a specific SCM platform that supports PRs (GitHub, GitLab, Azure DevOps, etc.)



- Detect **pinned dependencies** in many file formats (e.g., `requirements.txt` for Python, `pom.xml` for Maven, etc.)
- **Query** the corresponding **package registry** (PyPi, Maven Central, ...) for updated versions
- For each outdated dependency: **create branch and corresponding PR**

N

chore(deps): update dependency bazel to v7 #20

Open

renovate wants to merge 1 commit into `main` from `renovate/bazel-7.x`

Conversation 0

Commits 1

Checks 0

Files changed 1

+1 -1

renovate bot commented on Jun 22 · edited

MENDRenovate

This PR contains the following updates:

Package	Update	Change
bazel	major	6.4.0 -> 7.3.0

Release Notes

► bazelbuild/bazel (bazel)

Configuration

Schedule:

Branch creation - At any time (no schedule defined), Automerge - At any time (no schedule defined).

Automerge:

Disabled by config. Please merge this manually once you are satisfied.

Rebasing:

Whenever PR becomes conflicted, or you tick the rebase/retry checkbox.

Ignore:

Close this PR and you won't be reminded about this update again.

Reviewers

No reviews

Still in progress? Convert to draft

Assignees

No one—assign yourself

Labels

dependencies depManager:bazelisk

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

None yet

chore(deps): update dependency bazel to v7 #20

Open

renovate wants to merge 1 commit into `main` from `renovate/bazel-7.x`

Conversation 0

Commits 1

Checks 0

Files changed 1

+1 -1

Changes from all commits

File filter

Conversations

Jump to

0 / 1 files viewed

Review in codespace

Review changes

2 .bazelversion

@@ -1 +1 @@

1 - 6.4.0

1 + 7.3.0

N

What is Renovate **not**?

- Renovate does *not* tell you whether *all* your dependencies are **secure**!
- Renovate can (sometimes) indicate that PRs fix CVEs, but only the **directly** declared ones (e.g., not the **transitive** ones declared in `package-lock.json`)



N

Configuration flexibility

- Bundle dependencies into one PR
- Ignore specific dependencies or versions
- Configure update frequency (to avoid spam)
- Automatic merging of PRs
- Delay PRs for <n> days

N

Operating modes



Self-hosted

- You run the CLI regularly, typically in a scheduled CI/CD pipeline – there is also a [K8s operator](#)
- You define global configuration values for the CLI
- Advantages:
 - Guarantees privacy of your code
 - Better control over breaking Renovate changes
 - Lets you configure Renovate to run custom shell commands before committing (“postUpgradeTasks”)
- Disadvantage: requires compute time

Managed app (github.com)

- Mend offers a free-to-use hosted offering, for public open-source software
- Installable via GitHub app
- **We use this mode in this workshop**
- Advantages:
 - No setup / maintenance / compute time needed
- Disadvantages:
 - Third party (Mend) has access to your code
 - They introduce breaking changes you need to react to

N

Renovate

>

Dependabot





Renovate

- Better overview via Dependency Dashboard (implemented as issue)
- Better grouping support (across ecosystems)
- Ecosystem breadth: Supports more package managers and version file types, allows defining custom regex / json-based managers
- Platform support: Works on GitHub, GitLab, Bitbucket, Azure DevOps, Gitea
- Monorepo support: Better handling of multi-package repositories
- Presets: Shareable, reusable config across organizations

N

Let's go

<https://tlk.io/renovate-mob>

